

Analyse d'impact relative à la protection des données (AIPD)

MediPlan — plateforme de prise de rendez-vous médicaux · version **simplifiée** (modèle CNIL)

FONDEMENT RGPD art. 35 · données de santé (art. 9)	RESPONSABLE DE TRAITEMENT Hôpital régional
RÉDACTEUR Analyste technique · HealthBridge	DATE 07/07/2026 · v1.0

Une AIPD est obligatoire pour les traitements de **données de santé à grande échelle**. Ce document en présente une version simplifiée selon le modèle CNIL, en trois volets : **description du traitement**, **évaluation de la nécessité et de la proportionnalité**, et **mesures pour gérer les risques sur les droits des personnes**. Il se distingue de l'analyse EBIOS (qui protège le système d'information) en se plaçant du point de vue du **patient** et de ses droits. L'analyse EBIOS déjà réalisée alimente le volet 3.

1. Description du traitement

1.1 Présentation et finalités

MediPlan est la plateforme web de prise de rendez-vous médicaux d'un hôpital régional. Le traitement couvre la prise de RDV en ligne par les patients, la gestion des plannings des praticiens et du secrétariat, le suivi des dossiers patients et l'envoi de rappels e-mail/SMS. Il porte sur des **données de santé** (catégorie particulière, art. 9 RGPD). Finalités : moderniser le parcours patient, fiabiliser la prise de rendez-vous et faciliter le travail des équipes, tout en garantissant la sécurité des données (hébergement HDS obligatoire).

1.2 Responsabilités

Responsable de traitement : l'hôpital régional (établissement de santé). **Sous-traitants (art. 28 RGPD)** : HealthBridge (éditeur/intégrateur), l'hébergeur certifié **HDS** (ex. OVHcloud HDS), le prestataire d'envoi e-mail/SMS. La conformité est supervisée par le **DPO** de l'établissement. Aucune responsabilité conjointe identifiée.

1.3 Données, destinataires et durées de conservation

Donnée	Destinataires	Durée de conservation
Identité (nom, prénom, date de naissance)	Soignants, secrétariat	Durée du suivi + archivage légal du dossier
Coordonnées (e-mail, téléphone)	Secrétariat, service de notification	Durée du suivi
NIR (n° de sécurité sociale) — chiffré	Médecins (accès restreint)	Durée du dossier médical
Données de santé (antécédents, groupe sanguin, motif)	Médecins	20 ans (dossier médical)
Données de compte (rôle, e-mail, id Keycloak)	Administrateurs, IAM	Durée de la relation professionnelle
Rendez-vous (créneau, statut, salle)	Patient, praticien, secrétariat	Durée utile + archivage
Consentements	DPO / système	Durée du traitement + preuve
Journaux d'accès (audit)	RSSI / administrateurs	6 mois à 3 ans

Le dossier médical se conserve **20 ans à compter de la dernière consultation** (art. R1112-7 CSP ; jusqu'à 28 ans pour un mineur, 10 ans après décès). Durées exactes à arrêter avec le DPO.

1.4 Cycle de vie

Collecte (prise de RDV en ligne via compte Keycloak, ou saisie par le secrétariat ; recueil du consentement) → **Utilisation** (consultation du dossier par le praticien, gestion des plannings, envoi des rappels) → **Conservation** (base PostgreSQL hébergée HDS) → **Archivage / suppression** (purge à échéance, droit à l'oubli par pseudonymisation).

1.5 Supports

Matériels : serveurs de l'hébergeur HDS, postes des soignants et du secrétariat. **Logiciels** : PostgreSQL, API NestJS, frontend React, Keycloak (IAM), service de notification. **Canaux** : réseau interne, Internet en HTTPS/TLS, passerelle SMS/SMTP. **Personnes** : médecins, secrétariat, administrateurs, DPO, prestataires.

1.6 Référentiels applicables

RGPD (art. 9, art. 35) ; référentiel de certification HDS et art. L1111-8 CSP ; guide CNIL « Sécurité des données de santé » et modèle d'AIPD ; recommandations ANSSI et méthode EBIOS RM ; RGAA 4 (accessibilité).

2. Évaluation de la nécessité et de la proportionnalité

2.1 Nécessité et proportionnalité

- **Finalités** déterminées, explicites et légitimes ; pas de réutilisation à une finalité incompatible.
- **Base légale** : mission d'intérêt public / exécution (art. 6.1.e) ; pour les données de santé, art. 9.2.h (gestion des systèmes de soins) ; consentement (art. 9.2.a) pour ce qui le requiert.
- **Minimisation** : seules les données nécessaires sont collectées ; le NIR uniquement s'il est requis (identito-vigilance / facturation).
- **Exactitude** : données tenues à jour par le patient et le secrétariat.
- **Durées de conservation** limitées et justifiées, purge automatique et anonymisation en fin de cycle.

2.2 Mesures protectrices des droits des personnes

Droit / obligation	Mise en œuvre dans MediPlan
Information	Mention d'information / politique de confidentialité présentée à la collecte
Consentement	Table <code>consentement</code> versionnée ; retrait possible à tout moment
Accès et portabilité	Consultation et export de ses données par le patient
Rectification	Correction des données inexactes
Effacement (droit à l'oubli)	Anonymisation (<code>patient.anonymise</code>) — encadré par l'obligation légale de conservation du dossier médical : appliqué aux données non soumises à conservation et au terme de la durée légale
Opposition / limitation	Prévues
Sous-traitance	Contrats art. 28 avec l'hébergeur HDS certifié et le prestataire e-mail/SMS
Transferts hors UE	Aucun (hébergement HDS en France/UE)

3. Mesures pour gérer les risques sur les droits des personnes

Cette partie s'appuie sur l'analyse EBIOS, recentrée sur l'**impact pour les patients**. Le modèle CNIL raisonne sur trois événements redoutés.

3.1 Mesures de sécurité (rattachées aux risques EBIOS)

Mesure	Risque adressé
Chiffrement des données sensibles au repos (prouvé par le POC), clé hors base	R1
Chiffrement en transit (TLS 1.3)	R1
Contrôle d'accès RBAC / matrice d'habilitation (POC)	R2
Authentification forte (MFA via Keycloak)	R2
Journalisation des accès (<code>journal_acces</code>)	R1, R2
Requêtes paramétrées, validation des entrées (anti-injection)	R4
Sauvegardes chiffrées (règle 3-2-1) + tests de restauration	R7
Hébergement certifié HDS ; cloisonnement de <code>dossier_medical</code> ; anonymisation	R1, R5

3.2 Évaluation des événements redoutés (impact sur les personnes)

Événement redouté	Impacts sur les personnes	Sources	Gravité	Vrais.
Accès illégitime à des données (≈ R1 + R2)	Divulgence de données de santé → atteinte à la vie privée, discrimination (emploi, assurance), préjudice moral	Cybercriminel, interne malveillant, erreur humaine	Élevée	Réduite*
Modification non désirée de données (≈ R4)	Dossier médical erroné → mauvaise prise en charge, atteinte à la sécurité du patient	Faible applicative (injection, IDOR), erreur	Élevée	Réduite*
Disparition de données (≈ R7)	Perte du dossier → rupture de suivi, perte d'informations de soin	Rançongiciel, panne, absence de sauvegarde	Élevée	Faible*

* Vraisemblance **après application des mesures** de la section 3.1.

Synthèse : les trois événements ont une gravité élevée intrinsèque (données de santé), mais leur vraisemblance est ramenée à un niveau acceptable par les mesures — au premier rang desquelles le **chiffrement au repos avec clé hors base** (dont la faisabilité est démontrée par le POC), qui rend inexploitable tout accès illégitime à la base.

4. Validation

Plan d'action : reprend le plan de traitement de l'EBIOS (mesure → responsable → délai → risque résiduel). **Avis du DPO** : à recueillir avant mise en œuvre. **Avis des personnes concernées** : le cas échéant. **Décision du responsable de traitement** : le traitement peut être mis en œuvre **sous réserve** de la mise en place effective des mesures décrites.

5. Sources

RGPD (UE 2016/679), art. 9 & 35 · Code de la santé publique, art. L1111-8 et R1112-7 · CNIL — guide « Sécurité des données de santé », modèle et logiciel PIA · ANSSI / EBIOS Risk Manager · Documents projet : `analyse-risques-v2.pdf` (EBIOS), `schema.sql` (mesures en base), `dossier_poc/` (chiffrement au repos + RBAC).